# EWB Courses: AI-Powered Cybersecurity

### Assessment 01: Security Foundations

**Name:** Nandhana **Batch/Group:** Cyber security intern **Issued:** 18 October 2026

All work below is based only on the fictional data supplied in the assessment. No real systems, passwords or personal data were used.

## Task A: Secure a student account

### *A1 and A2: Risk table*

| Risk | Asset | CIA impact | Control | Limitation |
|---|---|---|---|---|
| 1. Same short password reused for email and learning portal | Email and portal accounts | **Confidentiality, integrity:** a guessed or leaked password opens both accounts; attacker can read data and change work. | Unique long passphrase for each account, stored in a password manager. | Manager master password becomes a key point of failure; does not stop phishing. |
| 2. Approving unexpected sign-in (MFA) prompts | Account session / MFA approval | **Confidentiality, integrity:** approving an attacker's prompt gives them a valid session. | Deny and report unexpected prompts; use authenticator app with number matching. | Relies on user behaviour; a convincing phishing page can still capture codes. |
| 3. Postponed device updates | Laptop OS, apps, stored files | **All three:** known flaws allow malware, data theft or ransomware that locks files. | Turn on automatic updates and restart regularly. | Does not stop unknown (zero-day) flaws; updates may need a restart and can occasionally cause compatibility issues. |
| 4. Only one copy of the project | Project files | **Availability** (and integrity): loss, theft, failure or ransomware destroys the only copy. | Keep backups: cloud sync with version history plus an offline copy. | Sync can copy deletions or corruption; backups are useless if never test-restored. |
| 5. Friend uses laptop under Mira's signed-in account | Accounts, sessions, personal files | **Confidentiality, integrity:** friend can read, change or delete files and act as Mira. | Create a separate guest/standard account for the friend; auto-lock screen; sign out when done. | Relies on habit; does not protect an unencrypted laptop if it is lost or stolen (add disk encryption). |

### *Top three priorities*

1. **Replace the reused password with unique ones, email first.** Email resets other accounts, and one reused password means one failure exposes everything. This is the most likely and highest-impact weakness.
2. **Stop approving unexpected prompts and switch to number-matching MFA.** MFA is the last barrier after a password is exposed; approving blindly removes it.
3. **Stop shared use of the signed-in account.** Anyone at the laptop already has full access without any hacking skill, and a guest account is quick and free to set up.

Backups and updates come next (within the week): they reduce impact and exposure but do not block the most direct routes to account takeover.

### *A3: Authentication vs authorisation*

**Authentication** proves who you are. When Mira enters her password and approves an MFA check, the portal confirms that she is Mira. **Authorisation** decides what an authenticated identity may do. Once logged in, Mira can view her own courses and submit her assignments, but cannot edit grades or open other students' work. Authentication comes first, then authorisation. If the password is stolen, the attacker passes authentication and gets all of Mira's permissions, which is why strong authentication matters.

# Task B: Analyse a suspicious message

### *B1: Warning signs (evidence is fictional; sample addresses were not visited)*

| Quoted phrase | Why it needs scrutiny |
|---|---|
| "FINAL WARNING - scholarship expires in 20 minutes" | Artificial urgency pushes people to act before checking. Real offices rarely demand action in minutes. |
| awards@**campus-awards.example** | The college normally uses campus.example. This is a different, look-alike domain. |
| Reply-To: help@**personal-awards.example** | Replies go to a third domain that differs from both the sender and the college, a common way to redirect responses. |
| "enter your college password and OTP" | Legitimate services do not ask for a password and OTP through a link in a message. Together they let an attacker log in live. |
| "Do not contact the college office because their system is unavailable" | Tries to isolate the victim from the one channel that could expose the scam. |

An additional sign: "Reply with a photo of your identity card" requests sensitive data that could be used for identity theft.

### *B2 to B3: Verification and response plan*

**Safe verification**

1. Do not click the link, reply, or enter anything. Do not use contact details in the message.
2. Open the college portal by typing the known address or using a saved bookmark, and check for the scholarship notice there.
3. Contact the scholarship or college office using a phone number or email from the official college website or student handbook.
4. Compare the sender domain with campus.example and report the message to IT/security if the office says it is not theirs.

**Why HTTPS or a display name is not proof:** HTTPS only means the connection to that site is encrypted; anyone, including a scammer, can obtain a certificate for their own look-alike domain. The display name "Scholarship Desk" is text the sender chooses freely and says nothing about who actually sent it.

**Response plan if a password and OTP were already entered**

1. **Contain now:** from a trusted device, go to the official portal (typed or bookmarked) and change the password; use a new, unique one.
2. Sign out of all other sessions and devices, and remove any unknown MFA methods, recovery emails or phone numbers.
3. Change the password anywhere else it was reused.
4. **Report:** tell college IT/security and the college office through official contacts, and pass on the message as they direct. Never share the password or OTP with anyone. If an ID photo was sent, tell the office too.
5. **Follow up:** review recent sign-in history and account activity, check for mail forwarding rules or changed settings, and watch for further phishing for the next few weeks.

### *B4: What cannot be established*

From this message alone I cannot establish whether the sender or website is actually malicious, or whether campus-awards.example is somehow owned by the college. The signs are strong indicators, not proof. Helpful evidence: confirmation from the college office, the college's list of official domains, and the full email headers (SPF/DKIM/DMARC results), reviewed by IT.

# Task C: Triage a sign-in alert

### *C1: Four-point timeline*

| Time (IST) | Observed (from logs / statement) | Interpretation |
|---|---|---|
| 09:00-09:01 | student07 password success and MFA approved from 192.0.2.10, the usual classroom egress. | Looks like normal activity. Student says no sign-in after 09:05. |
| 10:14-10:16 | From new IP 198.51.100.23: two failed passwords, then a success. | New IP alone is not proof of an attacker, but fail-then-success suggests guessing or a stolen password. A typo from another network is also possible. |
| 10:17-10:18 | MFA denied, then approved. Student states they approved a prompt around 10:18 to stop repeated requests. | Repeated prompts match 'MFA fatigue'. Since the student says they did not sign in, the prompts were probably triggered by someone else holding the password. |
| 10:20 | Session created from 198.51.100.23. | Access was granted. The session should be treated as possibly unauthorised until shown otherwise. |

### *C2: Explanations and checks*

**Likely explanation:** someone other than the student obtained or guessed the password, triggered repeated MFA prompts, and the student's approval at 10:18 completed an unauthorised sign-in. **Alternative:** the student (or someone they know) signed in legitimately from another network such as a phone hotspot or VPN, then misremembered; the IP identifies a network location, not a person.

**Two checks to tell them apart:**

1. Compare the session's device, browser/user agent and approximate location with the student's known devices, and ask whether they were on another network at 10:14.
2. Review the MFA prompt details (which device approved, any number matching) and what the session did after 10:20 (mailbox rules, file access, password or MFA changes), and whether other accounts saw failures from the same IP.

### *C3: Prioritised response actions for the authorised IT team*

1. **Preserve evidence:** export and securely store authentication, MFA and session logs (with timestamps, IP, device details) for student07 before making changes; note who did what and when.
2. **Protect the account:** revoke active sessions and tokens, force a password reset through a verified channel, and review and re-enrol MFA methods (ideally with number matching).
3. **Scope and monitor:** review activity after 10:20, check other accounts for the same IP, consider temporarily monitoring or blocking 198.51.100.23, and coach the student to deny and report unexpected prompts.

### *C4: Incident summary*

Logs show student07 signed in normally at 09:00 from the usual classroom IP. At 10:14-10:20, a different IP (198.51.100.23) had two failed passwords, then success, an MFA denial, an MFA approval and a created session. The student says they did not sign in and approved a prompt to stop repeated requests. This suggests possible MFA-fatigue account compromise, but the IP does not identify a person and a legitimate sign-in cannot be fully excluded. Priority: medium-high. Next action: IT should preserve logs, revoke sessions, reset the password and review account activity.

# Task D: Review an AI security answer

### *D1: Unsafe or unsupported claims and corrections*

| AI claim / action | Correction and reason |
|---|---|
| "The email is safe because it uses HTTPS." | HTTPS only encrypts the connection and does not prove legitimacy. The message has a look-alike domain, urgency and requests for credentials (Task B). CISA phishing guidance says to verify independently. |
| "The logs prove the person using 198.51.100.23 stole the password." | Logs show events, not identities. An IP address is a network location. The pattern suggests possible compromise, but how the password was obtained is unknown (Task C). |
| "MFA prevents every account compromise." | Overclaim. In Task C an MFA approval is part of the sign-in; phishing and prompt fatigue can also defeat MFA. It greatly reduces risk but is not absolute. |
| "Delete the suspicious logs." | Logs are evidence needed to investigate and scope an incident. They should be preserved, not deleted. |
| "Send the student's password to support so they can test it." | Passwords must never be shared, even with support. Legitimate support never needs it; the right action is a password reset via the official process. |

### *D2: Better prompt*

"This is a training exercise. Analyse ONLY the fictional evidence pasted below (a synthetic sign-in log and a fictional email). Do not assume anything about real people or systems. Do not ask for or accept passwords, OTPs or any real personal data. Respond in sections: (1) Observed facts, quoted from the evidence; (2) Interpretations and assumptions, labelled as such; (3) Alternative explanations; (4) What cannot be determined and what extra evidence would help; (5) Safe next steps, including preserving evidence. Give a confidence level (low/medium/high) for each conclusion and do not claim an IP address identifies a person. Evidence: [paste synthetic evidence here]"

### *D3: Corrected security advice*

Treat the message as suspicious, not proven malicious. Do not rely on HTTPS or a display name; check the sender domain against the official college domain and verify through a contact or portal you find independently. Never share passwords or OTPs with anyone, including support; if you entered them, change your password through the official site, sign out other sessions and report to IT. Logs show events, not people: an unfamiliar IP is a reason to investigate, not proof of who acted. MFA greatly reduces risk but does not prevent every compromise, so deny and report prompts you did not start. IT should preserve logs before cleanup, revoke sessions, reset credentials and review account activity. Record uncertainty and update conclusions as new evidence arrives.

### *D4: AI-use declaration and references*

**AI-use declaration:** Claude (Anthropic) used for drafting help; I reviewed and edited the content.

**Reference notes:**

1. CISA, Secure Our World (https://www.cisa.gov/secure-our-world): supports strong unique passwords with a password manager, multifactor authentication, software updates, and recognising and reporting phishing.
2. NIST, Generative AI Profile, AI 600-1 (https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf): describes confabulation (confident but false AI output) and the need to verify AI output against evidence, which supports the D1 corrections.